

Introduction

Security

The state of being free from danger or threat

- The safety of a state or organization against criminal activity such as terrorism, theft, or espionage
- Procedures to be followed or measures to be taken to ensure the security of a state or organization

Cyber Security

- The state of being protected against the criminal or unauthorized use of electronic data, or the measures taken to achieve this

General Security Objectives

Confidentiality

Only sender, intended receiver should “understand” message contents

- Sender Encrypts Message
- Receiver Decrypts Message

Authentication

Sender, Receiver want to confirm identity of each other (you are really talking to whom you think you are talking!)

Message integrity

Sender, Receiver want to ensure message not altered (in transit, or afterwards) without detection

Access and availability

Services must be accessible and available to users

Key Elements of Cybersecurity

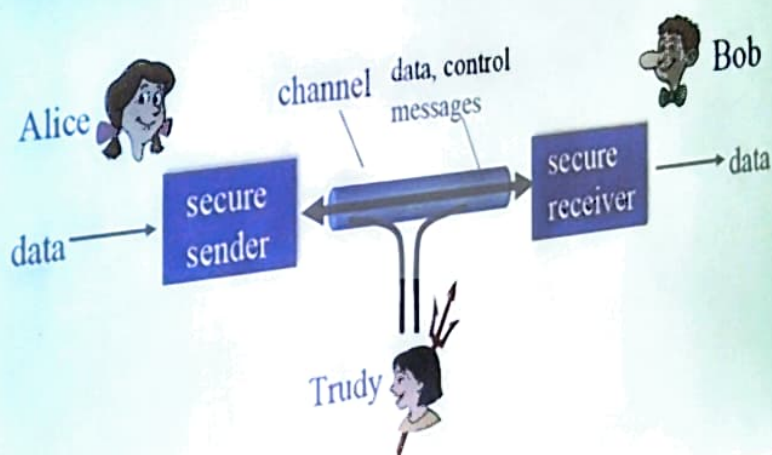
- **Application security**
 - Keeps software and devices free of threats
- **Information Security**
 - Protects integrity and privacy of data, both in transit and at rest (stored)
- **Network Security**
 - Secures computer networks from intruders (targeted attackers or opportunistic malware)
- **Disaster Recovery / Business Continuity Plan (BCP)**
 - DR policy dictates how an organization recovers from a cyber attack that causes data loss or affects operations
 - BCP: Plan an organization falls back to while trying to operate without certain resources
- **Operational Security**
 - Includes procedures for handling and protecting data assets
- **End-User Education**
 - Addresses the most unpredictable cybersecurity factor: people!

Why do we need Network Security?

- Internet not originally designed with (much) security in mind
 - *Original vision*: “a group of mutually trusting users attached to a transparent network”
 - Internet protocol designers playing “catch-up”
 - Security considerations in all layers!
- We now need to think about:
 - How bad guys can attack computer networks
 - How we can defend networks against attacks
 - How to design architectures that are immune to attacks

Friends and Enemies: Alice, Bob, Trudy

- Well-known in network security world
- Bob, Alice (lovers!) want to communicate “securely”
- Trudy (intruder) may intercept, delete, add messages



Friends: Alice, Bob

Who might Bob and Alice be?

- ... well, *real-life* Bobs and Alices!
- Web browser/server for electronic transactions (e.g., online purchases)
- On-line banking client/server
- DNS servers
- BGP routers exchanging routing table updates, etc



Bob



Alice

There are bad guys (and girls) out there!

Bad guys can:

- Eavesdrop: intercept messages
- Actively insert messages into connection
- Impersonation: can fake (spoof) source address in packet (or any field in packet)
- Hijacking: "Take Over" ongoing connection by removing sender or receiver, inserting himself in place
- Denial of Service: Prevent service from being used by others (e.g., by overloading resources)

Trudy



Vulnerability

- A flaw or weakness in system's defenses
 - It can be either at software, firmware, hardware, or service component level that can be exploited, causing a negative impact to confidentiality, integrity, or availability of the system
 - Vulnerabilities can allow attackers to run unauthorized code, access system information and steal, modify and destroy data.

Example: A house with unlocked door!

- Vulnerabilities in Design or specification
 - Implementation bugs
 - Operation & Management
 - misconfiguration settings
 - weak passwords/default passwords

Exposure & Breach

- Not every vulnerability results in an attack, and not every attack succeeds
 - Success depends on the degree of vulnerability, the strength of attacks, and the effectiveness of any countermeasures in place.
- **Exposure** refers to the state where vulnerability is visible/accessible and can potentially be exploited
 - **Example:** Leaving door wide open exposes vulnerability!
- **Breach:** An actual compromise of system/network leading to authorized access, data theft, etc
 - **Example:** Unauthorized entry into the house and theft.

Attack

- **Attack:** An intentional act by which an attacker attempts to evade security services & violate the security policy of a system
- **Attacker:** An adversary that is motivated and capable of exploiting a vulnerability in the system by launching attacks
- **Passive vs Active Attacks**
 - Passive attack attempts to learn or make use of information from a system but does not affect resources of that system
 - Monitoring of network traffic
 - Very difficult to detect, but feasible to prevent them with encryption
 - Active attack attempts to alter system resources or affect its operation
 - Man-in-the-middle (MITM) & DoS attacks
 - Very difficult to prevent them due to wide variety of vulnerabilities
 - Main goal is to detect attacks and recover the system to normal operation

Attackers

- **Types**

- Individual
 - Outsider
 - Insider
 - Trusted/Privileged Insider
- Group
 - Ad hoc
 - Established
- Organization
 - Competitor
 - Supplier
 - Partner
 - Customer
- State or State-sponsored actor

- **Capabilities**

- Time
- Money
- Training
- Access

- **Motivation/Intent**

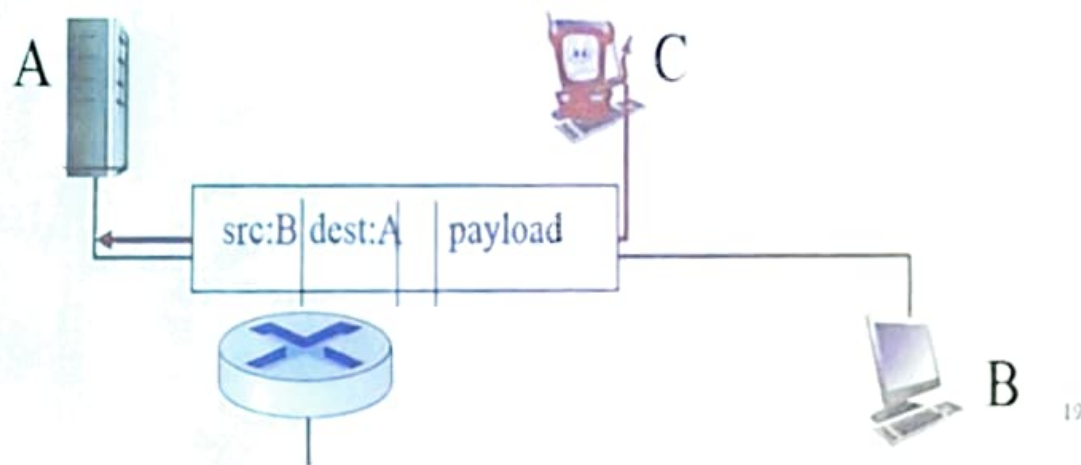
- Curiosity
- Fame
- Money
- National interest

BAD Guys do Eavesdrop

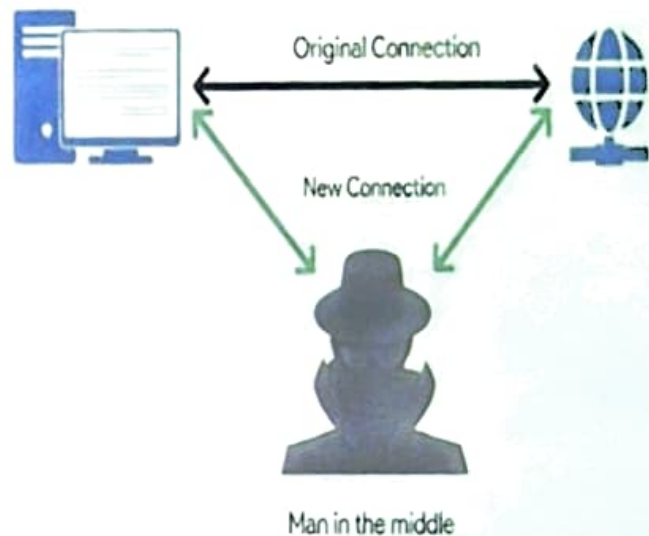
- By default, everything is transmitted in clear text
 - Usernames, passwords, content ...
 - No security offered by the transmission medium
- Different tools available on Internet
 - Wireshark/Kismet/Tcpdump/airodump-ng/...
- With the right equipment, it is possible to eavesdrop from few kilometers away in wireless networks
- Affects Confidentiality of data exchanged
- Countermeasures
 - Encryption and signal-hiding techniques

BAD Guys do Spoofing (IP, ARP, DNS)

- Injection of packet with false source address
 - Pretending to be someone else
 - **Example:** DNS spoofing redirects to fake sites



BAD Guys do Man-in-the-Middle (MITM) Attacks



- Attacker intercepts communication
- Affects Integrity, Availability and Confidentiality
- **Example:** Fake Wi-Fi Hotspot stealing credentials

BAD Guys do Denial of Service (DoS)/DDoS

Floods server with traffic, makes it unavailable

DDoS uses **multiple machines**



Attackers make resources (server, bandwidth) unavailable to legitimate traffic by overwhelming resource with bogus traffic

BAD Guys do Phishing and Social Engineering

Trex IPTV: cyrus@trexiptv.com | trexiptv@trexiptv.com | trexiptv.com

Why is this message in spam? This message is similar to messages that were identified as spam in the past.

Report not spam



- **Phishing** = Fake emails/websites to steal info
- **Social engineering** = Tricking people into giving access

BAD Guys do SQL Injection (related to web security)

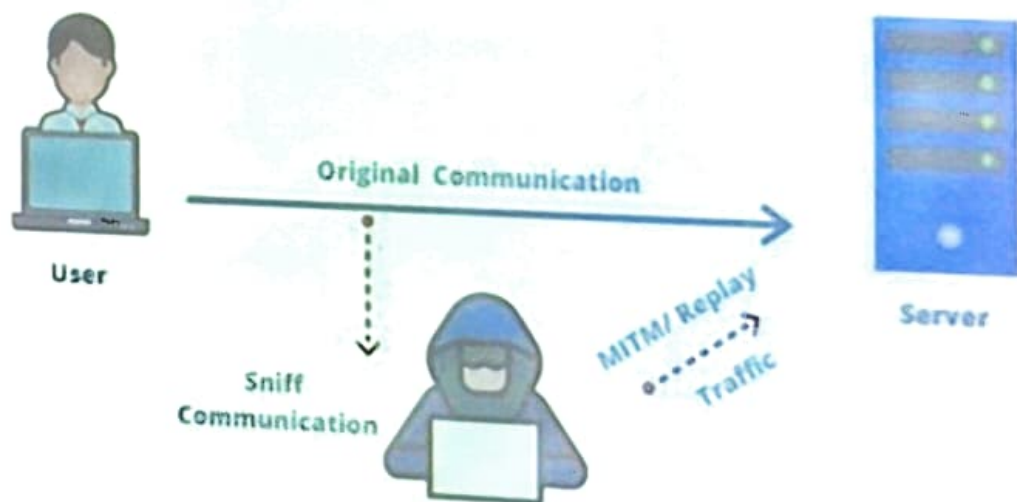
- Inserting malicious SQL queries into forms
- Can reveal/modify sensitive database info

A Malicious SQL Injection Network



BAD Guys do Replay Attacks

- Reusing captured valid data (like login tokens)
- Prevented with timestamps and encryption



BAD Guys do Ransomware and Malware



1. Bad guys create ransomware themselves or buy/lease it from other cybercriminals.



2. Cybercriminals use social engineering to gain access to your network or systems.



3. They use the malware to digitally encrypt all your IT systems and data possible.



4. Attackers use your encrypted sensitive data as leverage to force you to pay a ransom.

In some cases, attackers will exfiltrate your data prior to encrypting your systems.

- Ransomware encrypts files until ransom is paid
- Malware includes viruses, worms, trojans

WORST Guys do Insider Threats

- Employees misusing access
- Harder to detect than external hackers



Insiders have legitimate access to data



Remote working and using personal devices



Use of third-party applications

Types of Insider Threats



Malicious Insider



Negligent Insider



Compromised Insider



Accidental errors

Network Security Principles



Motivation: To protect data and systems by following core rules like confidentiality, integrity, availability, and access control.

Challenges: Hard to balance strong security with usability while keeping up with evolving threats.

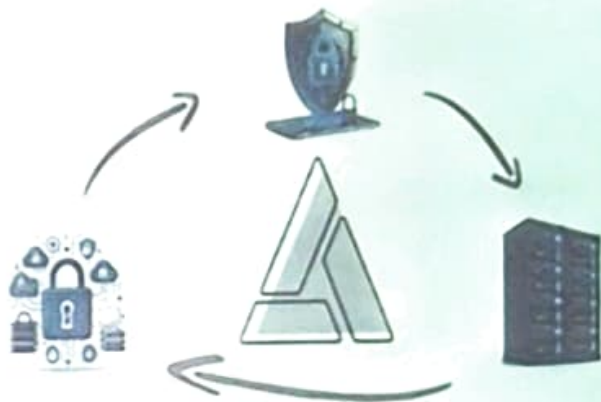
Evolving insider and external threats in computing

CIA Triad

Confidentiality – Ensures only authorized users can access data (e.g., passwords, encryption)

Integrity – Protects data from being altered without detection (e.g., hashing)

Availability – Systems and data must be accessible when needed (e.g., DDoS protection).



- Example: Online banking requires all three – private access, accurate balances, 24/7 availability.

Authentication, Authorization, and Accounting (AAA)

- **Authentication** – Proves identity (passwords, biometrics, tokens)
- **Authorization** – Determines what resources a user can access after authentication
- **Accounting** – Process of tracking and logging user activities and resource consumption



IDENTITY

Who do you claim to be?



AUTHENTICATION

Are you really who you claim to be?



AUTHORIZATION

What are you allowed to do?



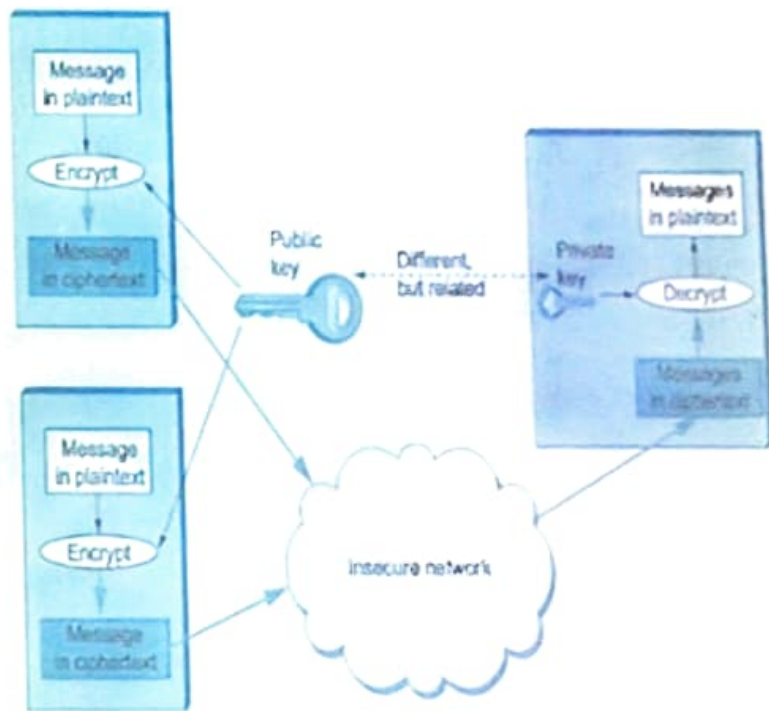
ACCOUNTING

What did you actually do?

- **Example:** logging into bank acc (auth) then accessing your money only (authorization) and maintain a comprehensive record of user activity for auditing (Accounting)

Public Key Infrastructure (PKI)

- Manages digital certificates & keys
- Ensures secure communication (used in HTTPS)



Conclusion

Lines of defense:

- Network security- a need of the hour !
- CIA- Confidentiality, Integrity, and Availability
- Next- Security in various layers
- Operational Security
- Wireless Network Security

... lots more on security (throughout, Session 2)

